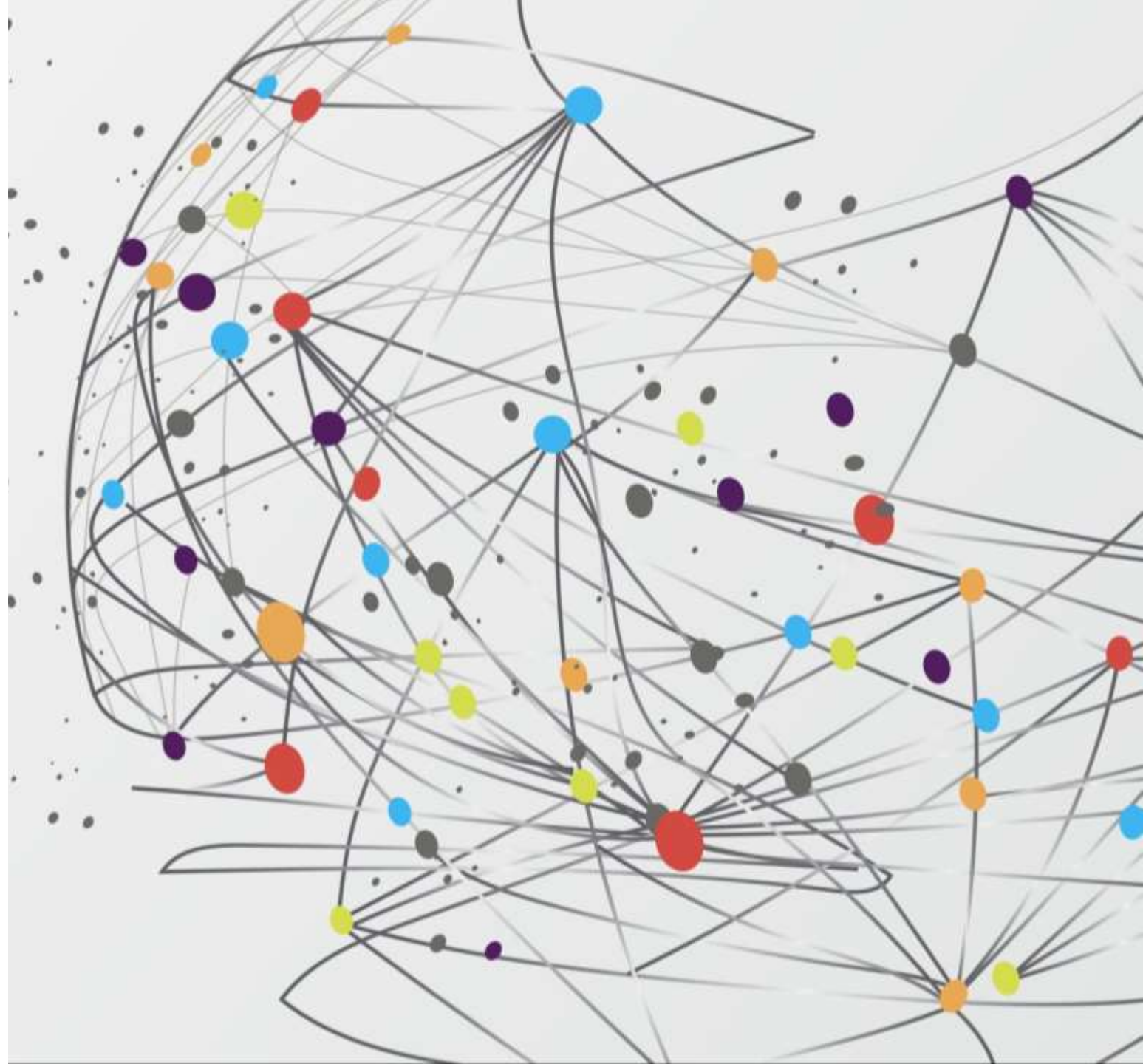

SİBER GÜVENLİĞE GİRİŞ

BÖLÜM 8 PREVENTION FROM CYBERATTACKS

Dr. Öğr. Üyesi Ahmet Kaşif

ahmet.kasif@btu.edu.tr



8.1 INTRODUCTION

8.1.1 THE GROWING THREAT OF CYBERATTACKS

Impact: Billions of dollars lost by businesses, governments, defense, and other sectors.

Evolution: Attacks are becoming more technologically advanced and ideologically driven.

Methods: Exploiting weaknesses in computers, web pages, networks, databases, and user awareness.

Goal: Preventing cyberattacks requires a proactive and informed approach.

8.1.2 THE HUMAN ELEMENT IN CYBERATTACK PREVENTION

Cybersecurity Awareness Includes:

- Continuous education about cybersecurity.
 - Emphasizing the importance of password security.
 - Training on software updates.
 - Guidelines for handling unknown emails.
 - Training on social engineering tactics.
 - Implementing proper system logout and monitoring.
-

Impact: Awareness creates a strong defense against cyber threats.

Statistics (Small Biz Trends research):

- Over 52% of cyberattacks on small businesses are due to human error and system failures.
 - 48% of attacks are deliberate.
 - Over 43% of global cyberattacks target small businesses due to higher success rates.
 - **Analogy:** A system can be "full-proof" (no inherent flaws) but difficult to make "foolproof" (resistant to user error).
-

8.1.3 CATEGORIES OF CYBERATTACK PREVENTION AND RESPONSE

Cyberattack Preventive Measures:

- Adhere to company security guidelines.
 - Never underestimate hackers.
 - Keep all software and tools updated.
 - Always back up your data (encrypted and protected).
 - Follow password management policies strictly.
 - Follow email use policy strictly.
 - Use Intrusion Detection and Prevention Systems (IDS/IPS).
 - Implement antivirus software and firewalls.
-

Cyberattack Corrective Measures (Post-Attack Response):

- Block suspected IDs and IPs (with caution).
 - Isolate affected systems.
 - Reroute traffic.
 - Block malicious traffic.
 - Implement disaster recovery mechanisms.
 - Assess the depth of the attack and damages.
 - Inform concerned security and law enforcement agencies.
 - Use backups to restore services.
-

8.1.4 STEPS AFTER A CYBERATTACK (DETECTION AND RESPONSE)

Steps After Detection:

- **Survey:** Assess vulnerability, damage, and attackers.
- **Limit:** Contain the attack by blocking, diverting, and isolating.
- **Record:** Document the impact (effects, levels, disruptions).
- **Engage:** Involve concerned agencies and authorities.
- **Notify:** Inform affected users and seek legal counsel.
- **Learn:** Analyze the attack to improve preventive measures.

Challenge: Preventing cyberattacks is complex due to the unknown nature of attackers, their locations, and timing.

8.2 ALGORITHMS AND TECHNIQUES

8.2.1 THE SCIENCE OF CYBERATTACK PREVENTION

Fundamental Principle: Despite security measures, 100% safety is not guaranteed.

Cyberattack Prevention Framework:

- Detection of cyberattacks
 - Prediction of cyberattacks
 - Prevention of cyberattacks
 - (Some experts include Response)
 - **Approach:** Three major activities utilizing different algorithms.
-

8.2.2 CYBERATTACK DETECTION: IDENTIFYING THREATS

Algorithms Used:

- **Machine Learning Algorithms:** Learn traffic patterns, language, code, behavior, biometrics, facial recognition. Used in Intrusion Detection Systems (IDS) to profile network usage and detect anomalies.
- **Evolutionary Algorithms:** Based on genetic approaches and natural selection. Identify various forms of cyberattacks and optimize solutions.
- **Statistical Algorithms:** Use Principal Component Analysis (PCA), Entropy Analysis (EA), and Markovian models to detect malicious activity. Often combined with evolutionary algorithms for improved accuracy.

Modern Systems: Hybrid algorithms and combinations are common in modern detection systems like IDS.

8.2.3 CYBERATTACK PREDICTION: ANTICIPATING THREATS

Algorithms Used:

- Machine learning-based algorithms
- Genetic algorithms
- Data analysis statistics algorithms

Key Difference from Detection: Prediction analyzes vulnerabilities *before* an attack is launched.

Method: Algorithms are used to construct a cyberattack tree based on critical episodes. High accuracy rates (around 95%) have been achieved.

Cyberattack Tree: Simulates the attacker's decision-making process, making it understandable for security professionals.

- **Emerging Tools:** New prediction models and tools are continuously entering the market.

8.2.4 CYBERATTACK PREVENTION: BLOCKING THREATS

Key Tool: Intrusion Prevention Systems (IPS) are crucial for preventing attacks.

Proactive Responsibilities: Security professionals and organizations must implement standard prevention measures:

- Follow security guidelines strictly.
 - Update software and tools.
 - Monitor internal and external threats.
 - Backup critical data securely.
 - Have an emergency response plan.
-

Core Algorithm: Sniffing and analysis of incoming network traffic.

Traffic Analysis: Monitors patterns, types, and characteristics to detect malicious intent.

Response: Suspicious traffic is blocked or redirected to dummy servers.

Implementation: Primarily done through IPS and sniffer software tools based on preconfigured criteria and actions.

8.3 FIREWALLS

8.3.1 THE FIRST LINE OF DEFENSE: FIREWALLS

Function: Acts as a traffic filter, monitoring continuously.

Purpose:

- Checks incoming traffic to prevent external attacks.
- Monitors outgoing traffic from internal networks.

Implementation:

- Software programs on devices (PCs, servers, routers).
- Dedicated hardware devices with specialized firewall software.

Importance: Crucial for network security for over 25 years.

8.3.2 ACTIVATING WINDOWS FIREWALL

Windows 10:

- Windows Firewall
 - Windows Defender Firewall
 - **Recommendation:** Configure both for maximum protection.
 - **Steps:** Start > Settings > Update & Security > Windows Security > Firewall & Network Protection > Turn On.
-

Windows 7:

- Windows 7 Firewall
- Windows Defender
- **Recommendation:** Enable and use both.
- **Enabling Steps:** Start > Control Panel > Windows Firewall.

8.3.3 CONFIGURING WINDOWS FIREWALL

Windows 7 Configuration:

- **Allow a program or feature:** Add ports and services. Unselect to block direct access.
 - **Change Notification Settings:** Modify settings for private and public networks.
 - **Allow another program:** Add programs not listed.
 - **Advanced Settings:** Configure inbound/outbound rules, connection security rules, and monitoring.
 - **Import/Export Policy:** Manage security policy configurations.
-

Enabling Windows Firewall Service:

- Run services.msc and locate "Windows Firewall."
- Set startup type (Automatic or Manual) and start the service.
- Warning:** Disabling the firewall puts your computer at risk.

8.3.4 UNDERSTANDING TRAFFIC RULES

Types of Traffic Rules:

- **Inbound Traffic Rules:** Apply to traffic entering the computer.
 - **Outbound Traffic Rules:** Apply to traffic originating from the computer.
 - **Rule Definition:** Based on port numbers, users, programs, services, and protocols.
-

Application: Applied to user profiles, network adapters, and service profiles.

Management: Rules can be created, modified, enabled, and disabled. Green indicates active, gray indicates disabled.

- **Rule Details:** Right-click a rule and select "Properties" to view protocol/ports and program/services.

8.3.5 CREATING INBOUND AND OUTBOUND RULES

Creating Inbound Rules:

- Advanced Settings > Inbound Rules > New Rule...
 - Rule Types: Program, Port, Predefined, Custom.
 - Example: Blocking a specific program's inbound connections.
-

Creating Outbound Rules:

- Advanced Settings > Outbound Rules > New Rule...
- Similar steps to inbound rules.
-

8.3.6 CONNECTION SECURITY RULES

Purpose: Secure data travel, encryption, and other security measures between specified computers.

Requirement: Same connection rules must be defined on both communicating computers.

Creating Connection Security Rules:

- Advanced Settings > Connection Security Rules > New Rule...
 - Rule Types: Isolation, Authentication exemption, Server-to-server, Tunnel, Custom.
 - Example: Server-to-Server rule requiring authentication using computer certificates.
-

8.3.7 MONITORING FIREWALL ACTIVITY

Monitoring Features:

- Displays active inbound, outbound, and connection security rules.
 - Shows active connections.
 - Provides general settings, firewall state, and logging settings.
 - **Access:** Found within the "Monitoring" section of the "Windows Firewall with Advanced Security" window.
-

8.4 INTRUSION DETECTION / PREVENTION SYSTEMS

8.4.1 INTRODUCTION TO IDS AND IPS

Goal: Provide in-depth understanding of IDS and IPS.

8.4.2 INTRUSION DETECTION SYSTEM (IDS)

Components:

- IDS devices/sensors
- Software applications

Function:

- Monitors network traffic and host operating systems.
 - Detects malicious activities using algorithms (including machine learning).
-

Types of IDS:

- **Network Intrusion Detection System (NIDS):** Monitors network traffic patterns. Alerts administrators or SIEM (Security Information and Event Management) systems to anomalies.
 - **Host Intrusion Detection System (HIDS):** Monitors files and events on operating systems.
 - **Application-based Detection System (AppIDS):** Monitors a specific application.
-

SIEM: A centralized system

- Collects logs and security data
 - Detects threats in real-time
 - Helps with compliance and investigations
 - How does it work ?
 - Data Sources → Firewalls, servers, endpoints, applications
 - Log Collection & Parsing
 - Normalization & Correlation
 - Threat Detection & Alerts
 - Dashboards & Reports
-

Detection Methods:

- **Anomaly-based detection:** Identifies deviations from normal behavior.
- **Signature-based detection:** Matches known attack patterns.

Capabilities:

- Detects both external and internal hacking attacks.
 - HIDS takes frequent file images and compares them for changes.
-

8.4.3 IDS FUNCTIONS

IDS Functions (Sequential Order):

- 1. Data Collection:** Gathers network traffic or system event data.
 - 2. Feature Selection:** Identifies relevant data attributes for analysis.
 - 3. Analysis of Data:** Uses algorithms to detect malicious activity.
 - 4. Action:** Alerts administrators or triggers automated responses.
-

Challenge: Securing networks and servers is a growing challenge.

Solution: Emerging security technologies like IPS.

8.4.4 INTRUSION PREVENTION SYSTEM (IPS)

Limitations of Firewalls and IDS:

- **Firewalls:** Block traffic based on ports but can be bypassed by attacks using allowed ports.
- **IDS:** Detects malicious traffic but does not automatically prevent it.

IPS Advantage: Detects, analyzes, and *prevents* intrusions.

8.4.5 ADVANTAGES OF IPS

Advantages of IPS:

- Comprehensive network security.
 - **Robust protection** against attacks.
 - Details of cyberattack origination.
 - **Automated response** and event recording.
 - **Instant alerts** and **preemptive actions**.
 - Stops access to email contacts.
 - Prevents reversal of system directories.
 - Protects all system and network resources.
-

8.4.6 TYPES AND APPROACHES OF IPS

Types of IPS:

- **Host-based Intrusion Prevention System (HIPS):** Software-based (usually).
- **Network-based Intrusion Prevention System (NIPS):** Appliance-based (usually).

IPS Approaches and Algorithms:

- **Protocol anomaly detection:** Detects deviations from expected protocol behavior
 - **Stateful signature detection:** Monitors session context to match known threat signatures
 - **Kernel-based approach:** Analyzes traffic at the OS kernel level for low-level threats
 - **Sandbox analysis:** Executes suspicious code in an isolated environment to observe behavior
 - **Heuristic approach:** Uses rule-based logic to detect new, unknown threats
 - **Combined/hybrid approach:** Integrates multiple techniques for enhanced detection accuracy
-

Modern IPS:

- Relies on multiple approaches for effective threat detection and prevention.

HAFTA 9'DAN DEVAM

8.5 AUTHENTICATION USING HASH

8.5.1 INTRODUCTION TO HASHING

Function: Transforms variable-length input into fixed-length output (hash).

Purpose:

- Ensures data integrity (detects alterations).
 - Authenticates sender identity.
 - Used for fast data indexing and retrieval in databases.
-

Key Techniques:

- Cryptographic Hash Functions (CHFs)
- Message Authentication Code (MAC)
- Digital Signature (DS)

8.5.2 HASHING FOR AUTHENTICATION

Hashing Methods for Authentication:

- Message Digest 2 (MD2)
 - Message Digest 4 (MD4)
 - Message Digest 5 (MD5)
 - Secure Hash Algorithm (SHA)
-

Key Difference: MAC and DS use private keys for sender authentication, while CHF's do not.

- **Cryptographic Functions on SSL:** MD5 and SHA are commonly used to secure data transmission over SSL encrypted connections (without requiring a separate secret key over the SSL connection itself).

8.5.3 MESSAGE DIGEST 5 (MD5)

Function: Takes input of any length and produces a fixed 128-bit hash.

Purpose: Message authentication for originality and integrity.

Standard: Governed by the Internet Engineering Task Force (IETF) via RFC 1321.

Security Concerns: 128-bit encryption is no longer considered highly secure for modern cybersecurity. Recommendations are for 256-bit or higher.

- **History:** Part of a series of MD algorithms (MD2, MD4, MD5) designed by Ronald Rivest. MD6 is a later 256-bit version.
-

8.5.4 SECURE HASH ALGORITHM (SHA)

Versions: SHA0, SHA1, SHA2, SHA3.

Development: Developed by the US National Security Agency (NSA).

Governance: Published and governed by the National Institute of Standards and Technology (NIST).

SHA3: The latest standard, capable of 224-bit, 256-bit, 384-bit, and 512-bit encryption.

- **Common Usage:** SHA3 with 256-bit encryption is widely used.

8.6 MULTI-FACTOR AUTHENTICATION

8.6.1 THE POWER OF MULTI-FACTOR AUTHENTICATION

Importance: Strong passwords alone are not enough; MFA is highly recommended.

- **Function:** Requires multiple credentials for access, not just a password.

8.6.2 THE FACTORS OF AUTHENTICATION

Three General Categories:

- **Knowledge:** Something only the user knows (e.g., security questions).
 - **Biometrics:** Something unique to the user (e.g., fingerprints).
 - **Possession:** Something the user has (e.g., one-time password).
-

Examples of Second Factors:

- Short code sent via mobile phone
 - User-generated PIN
 - One-time password (OTP)
 - Digital signature
 - Fingerprints
 - Key fobs
 - Digital card swiping
-

8.6.3 WHY MULTI-FACTOR AUTHENTICATION MATTERS

Vulnerability of Passwords:

- Fast computer processors can crack passwords through brute-force attacks.

Protection with MFA:

- Even if a password is stolen, the attacker needs additional factors to gain access.
 - MFA methods like OTPs, biometrics, or mobile codes are difficult for attackers to obtain.
-

Benefits of MFA:

- Alerts users to unauthorized login attempts.
- Provides a strong defense against hacking.

Common Implementation:

- Two-factor authentication (2FA) using mobile or email is widely used.
-

8.6.4 ACTIVATING TWO-FACTOR AUTHENTICATION (GOOGLE)

Popular Services:

- Google, Yahoo, Hotmail, Facebook, YouTube

Steps to Activate 2FA on Google Account:

1. Log in to your Google account.
 2. Go to Google Account settings.
 3. Click "Security."
 4. Click "2-Step Verification."
 5. Click "Get Started" and enter your password.
-

-
6. Select your country and enter your phone number. Choose to receive codes by text or call.
 7. Enter the verification code sent to your phone.
 8. Click "TURN ON" to confirm.
 9. (Optional) Add "Google Prompt" for passwordless login on trusted devices.
 10. Follow the prompts to set up Google Prompt on your phone.
 11. Verify the Google Prompt setup.
-

8.6.5 CREATING APPLICATION-SPECIFIC PASSWORDS (GOOGLE)

Purpose:

- Provides secure access for apps without exposing your main Google password.

Steps to Create App Passwords:

1. Log in to your Google account.
 2. Go to Google Account settings.
 3. Click "Security."
 4. Click "App Passwords" and verify your password.
 5. Select the app and device type.
-

-
6. Click "GENERATE."
 7. Copy the generated app password.
 8. Enter the app password in the third-party application.
 9. App passwords are saved for future use.
-

8.6.6 SECURITY MEASURES FOR LOST DEVICES

Actions to Take:

- 1. Revoke App Passwords:** Go to account settings > Security > App Passwords and delete the passwords. This will log out apps on the lost device.
 - 2. Change Your Google Password:** And any backup email passwords.
 - 3. Ensure Backup Phone Number is Added:** To recover your account if you lose access to your primary phone.
 - 4. Save Backup Codes:** Consider saving Google's backup codes in a safe place.
-

8.7 MAC COMPUTER FIREWALL CONFIGURATION

8.7.1 INTRODUCTION TO MACOS FIREWALL

Operating System: macOS (formerly OS X).

Default Behavior: The firewall blocks incoming traffic to unused ports by default.

Importance: Enabling the firewall helps prevent hackers from scanning your computer's security settings through open ports.

- **Goal:** Learn how to configure and activate the macOS firewall.

8.7.2 ACCESSING FIREWALL SETTINGS ON MACOS

Steps:

1. Open the **Apple Menu**.
2. Choose **System Preferences**.
3. Click the **Security & Privacy** icon.
4. Select the **Firewall** tab.

Administrator Access: Click the **Lock icon** at the bottom and enter your administrator password to make changes.

8.7.3 ENABLING AND DISABLING THE FIREWALL

Controls:

- Click **Turn Off Firewall** to disable it.
- If disabled, a **Start** button will appear to turn it on.

Recommendation: It is generally recommended to keep the firewall **enabled** for security.

8.7.4 CONFIGURING FIREWALL OPTIONS

Steps:

1. Click the **Firewall Options...** button.
 2. A list of applications will appear.
 3. Use the (–) sign to remove an application from the allowed list.
 4. Use the (+) sign to add a specific application to the allowed list.
-

8.7.5 ADVANCED FIREWALL SETTINGS

Advanced Options:

- **Enable Stealth Mode:** Prevents the computer from responding to probing attempts (like ping commands).
 - **Block all incoming connections:** Stops traffic to all ports on your computer.
 - **Automatically allow built-in software to receive incoming connections:** Allows default macOS applications to receive connections without explicit permission.
 - **Applying Changes:** Click **OK** to save the settings and close the window.
-

8.7.6 IMPORTANT CONSIDERATIONS

Limitations:

- Connections using proprietary protocols (like AppleTalk) might not be affected by the firewall settings.
- ICMP (ping) requests are blocked by enabling **stealth mode**, which can prevent external port and application status checks.

8.8 CHOOSING THE RIGHT BROWSER

8.8.1 THE IMPORTANCE OF YOUR BROWSER CHOICE

Analogy: Your browser is the vessel you use to navigate the internet.

Risk of Poor Choice: Old or unreliable browsers can expose you to security threats.

Goal: Understand how to choose the right browser for your needs.

8.8.2 FACTORS TO CONSIDER WHEN CHOOSING A BROWSER

Key Information to Gather:

- **Your System Information:** Operating system, RAM, processor, etc.
 - **Your Browsing Activities:** Basic surfing, multimedia, plugins, etc.
 - **Level of Security You Need:** Basic protection, advanced privacy features, etc.
-

8.8.3 STEPS TO CHOOSE THE RIGHT BROWSER

Steps:

- 1. Check Your System Configuration:** (Control Panel > System) Note your OS, RAM, etc.
 - 2. Search for Compatible Browsers:** Use search engines to find browsers suitable for your OS.
 - 3. Research Top-Rated Browsers:** Look for reputable tech review websites.
 - 4. Compare Features and Performance:** Pay attention to speed, security features, plugin support, and system requirements.
-

8.8.4 BROWSER RECOMMENDATIONS BASED ON NEEDS

Recommendations:

- **Fast Performance (Basic Features):** Midori, Vivaldi, Torch.
 - **Performance, Reliability, Features (Windows 7):** Google Chrome, Mozilla Firefox.
 - **Slow Internet (Fastest Browsing):** Text-based browsers (Elinks, WebIE, Lynx, Labnol).
 - **Plugins and Third-Party Apps:** Mozilla Firefox, Google Chrome (wide range of support).
-

8.8.5 FINAL STEPS: DOWNLOAD AND INSTALL

Action:

- 1. Download:** Visit the official website of your chosen browser.
 - 2. Install:** Follow the on-screen instructions to install the browser on your computer.
 - 3. Surf:** Start browsing the internet with your new, hopefully more secure and efficient, browser.
-

8.9 SECURE SOCKETS LAYER

8.9.1 INTRODUCTION TO SECURE SOCKETS LAYER (SSL)

Purpose: Ensures secure and reliable transactions between clients and servers.

- **Mechanism:** Establishes an encrypted connection.

8.9.2 ENCRYPTION METHODS USED BY SSL

Common Encryption Types:

- **Symmetric Encryption:** Uses the same key for both encryption and decryption (faster).
- **Asymmetric Encryption:** Uses two separate keys (public and private) for encryption and decryption (more secure for key exchange). Modern asymmetric encryption uses 2048-bit keys (1024-bit is no longer considered very safe).

8.9.3 SSL CERTIFICATES: ESTABLISHING TRUST

SSL Certificate:

- Purchased from Certificate Authorities (CAs) after website and business verification.
- Requires generating a Certificate Signing Request (CSR) containing server information and a private key.
- The CA issues the SSL certificate, which is then installed on the web server.

Outcome: Enables secure and encrypted communication between the browser and the server.

8.9.4 ESTABLISHING A SECURE SSL CONNECTION

Steps:

- 1.Browser Request:** User attempts to access a secure website via "HTTPS" (e.g., `https://websiteURL`).
 - 2.Server Response:** The web server sends its SSL certificate to the requesting browser.
 - 3.Certificate Verification (SSL Handshake):** The browser authenticates and verifies the validity of the SSL certificate.
 - 4.Padlock Icon:** Upon successful verification, a padlock icon appears in the browser's address bar.
 - 5.Secure Connection Established:** All subsequent communication between the browser and server is fully encrypted and secure.
-

8.9.5 THE IMPORTANCE OF SSL FOR WEBSITES

Benefits of SSL:

- **Security:** Protects data integrity and confidentiality.
- **Trust:** Increases visitor confidence in the website.
- **Conversion Rate:** Can lead to higher engagement and transactions.
- **SEO:** May positively impact website traffic.

Recommendation: Avoid visiting non-SSL enabled websites.

8.10 VIRTUAL PRIVATE NETWORK

8.10.1 INTRODUCTION TO VIRTUAL PRIVATE NETWORKS (VPNS)

Analogy: Think of a VPN as a secret, protected highway within the public road system of the internet.

Alternative Name: Tunneling protocol on public networks.

Goal: Understand the characteristics and benefits of using a VPN.

8.10.2 KEY CHARACTERISTICS OF A VPN CONNECTION

Main Characteristics:

- Secure, private, and anonymous routing through a tunnel.
 - Encapsulation of one protocol within another to hide communication details.
 - Routing communication through a proxy server.
 - Hiding internet activities from external interception.
-

-
- Masking your real IP address with a VPN IP address.
 - Hiding browsing history from even service providers.
 - Concealing your geographic location.
 - Masking your device identity.
 - Establishing a complete, secure connection from your device to the network.
-

8.10.3 HOW VPNS ENHANCE SECURITY AND PRIVACY

Normal Internet Communication: Data packets can be intercepted and decrypted by hackers.

VPN Communication:

- Completely hidden, private, and secure through an encrypted tunnel.
- Near impossible to intercept and interpret.

Use Cases:

- Corporations and government organizations for secure remote work.
-

8.10.4 TYPES OF VPN CONNECTIONS

Two Major Types:

- **Site-to-Site VPN Connections:** Connect multiple fixed locations (e.g., corporate offices) over the public internet using private or service provider proxy servers.
 - **Remote-Access VPN Connections:** Allow individual users (e.g., remote workers) to securely access private networks (e.g., corporate networks) over the internet.
-

8.10.5 THE TECHNOLOGY BEHIND VPNS

Mechanism:

- **Encryption:** Encrypts data before it's transported through the private tunnel.
 - **Protocol Masking:** Hides the original communication protocol within the VPN protocol.
 - **Tunnel Creation:** Establishes a secure link between a proxy server and the VPN-enabled device.
 - **Packet Encapsulation:** The original data packet is encrypted at the network layer and then repackaged with a new IP header for internet travel, disguising both data and message attributes.
-

8.10.6 ADVANTAGES OF USING A VPN

Main Advantages:

- Higher level of privacy.
- Greater data security.
- Better reliability.
- Anonymity online.
- Reduced cost of connection (compared to dedicated private lines).

Overall Impact: Helps maintain a high level of cybersecurity, preventing various cyberattacks on your data and communications.
